SSH Brute Force Incident Report **Jeaneth Lliguicota**
Home-Lab October 2026

Environment:

The lab runs on Proxmox VE, hosting four virtual machines: Kali Linux (attacker), Metasploitable2 (target), OPNsense (firewall), and Wazuh on Ubuntu (SIEM). The lab uses two network segments: vmbr0 and vmbr1. vmbr0 is connected to the physical NIC and the home network, and Wazuh sits on it. vmbr1 is purely virtual, with no physical NIC, and holds Kali, Metasploitable2, and OPNsense. OPNsense is the only VM connected to both segments, so any traffic crossing between them must pass through it. Metasploitable2 forwards its logs to Wazuh over syslog on UDP 514, which OPNsense allows through a firewall rule. IP addresses have been redacted.

What happened?

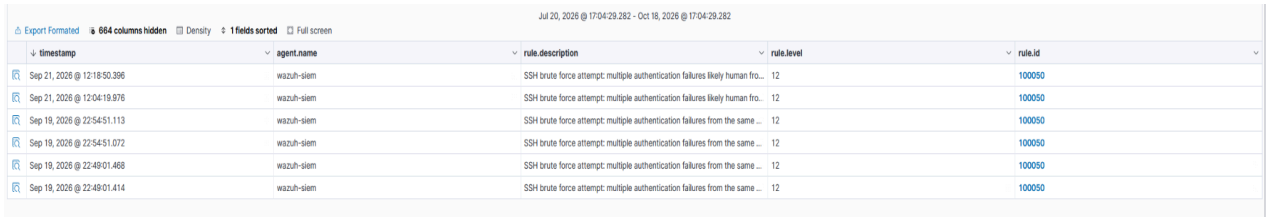
From Kali, a brute force attack was launched with Hydra against the SSH service on Metasploitable2, targeting the msfadmin account. Hydra tried 10 passwords from a wordlist file. None of them were correct so no access was gained.

Timeline:

Time	Rule	Level	What happened?
Sep 19 22:49:01	100050	12	First Hydra run with a 10 password wordlist. Our rule 100050 fired: “SSH brute force attempt: multiple authentication failures from the same source” (2 alerts)
Sep 19 22:54:51	100050	12	Second Hydra run to test the tuning, 100050 fired again (2 alerts), but nothing flagged the attack as automated.
Sep 21 12:04:19	100050	12	Third Hydra run. 100050 fired, now labeled “likely human.” 100051 did not fire, so its threshold was lowered from 10 to 5 failures.
Sep 21 12:18:50	100050 and 100051	12 and 14	Final Hydra run. Both rules fired 1 ms apart. 100050 labeled it “likely human,” and 100051 labeled it “likely automated” at level 14.

On Sep 19, rule 100050 fired twice per Hydra run. Each run sent 10 failed logins, and the rule triggered at 5 and again at 10 (Wazuh’s rule.firedtimes value of 2 confirms it). The full log for 22:54:51 alert shows four failures from separate SSH processes at nearly the same moment,

which a person typing by hand cannot do, confirming automated tools. Rule 100051 did not fire until Sep 21, after its threshold was lowered from 10 to 5 failures within 10 seconds. The final run triggered both rules, which revealed a tuning issue: 100050 still labels a fast automated attack as " likely human."



Jul 20, 2026 @ 17:04:29.282 - Oct 18, 2026 @ 17:04:29.282

Export Formated | 664 columns hidden | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 21, 2026 @ 12:18:50.396	wazuh-siem	SSH brute force attempt: multiple authentication failures likely human fro...	12	100050
Sep 21, 2026 @ 12:04:19.976	wazuh-siem	SSH brute force attempt: multiple authentication failures likely human fro...	12	100050
Sep 19, 2026 @ 22:54:51.113	wazuh-siem	SSH brute force attempt: multiple authentication failures from the same ...	12	100050
Sep 19, 2026 @ 22:54:51.072	wazuh-siem	SSH brute force attempt: multiple authentication failures from the same ...	12	100050
Sep 19, 2026 @ 22:49:01.468	wazuh-siem	SSH brute force attempt: multiple authentication failures from the same ...	12	100050
Sep 19, 2026 @ 22:49:01.414	wazuh-siem	SSH brute force attempt: multiple authentication failures from the same ...	12	100050

Figure 1: Rule 100050 alerts in Wazuh, Sep 19 and Sep 21



1 hit

Jul 20, 2026 @ 17:06:28.742 - Oct 18, 2026 @ 17:06:28.742

Export Formated | 664 columns hidden | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 21, 2026 @ 12:18:50.397	wazuh-siem	SSH brute force attempt: multiple authentication failures likely automatic...	14	100051

Figure 2: Rule 100051 alerts in Wazuh, Sep 21

Impact:

Kali was not able to get into Metasploitable2 since I created the Hydra wordlist without the correct password. No data was accessed or changed. The goal was to test how our SIEM processes an attack between an attacker and a target on the same isolated network segment. Without my custom rules, each failed login would only have appeared as Wazuh's built in rule 2501 at level 5, easy to miss among normal login failures, with nothing identifying it as a brute force attack. My rules raised it to level 12, and to level 14 when the speed showed it was Hydra automated brute force over SSH rather than a person.

Recommendations:

- Prevent, not just detect. Add rate limiting at the firewall (OPNsense) or on SSH, so an IP that fails more than 3 logins within 20 seconds is blocked. People who mistyped a password can still retry but automated tools are stopped.

- Automate the response: Connect Rule 100051 to Wazuh active response so the attacker's IP is blocked automatically when an attack is flagged as automated.

- Fix the label overlap: On the final run, 100050 labeled the attack "likely human" while 100051 labeled the same attack "likely automated." When 100051 fires, 100050 should stay quiet, so each attack gets one correct label

- Verify the rule settings: Check local_rules.xml since the README says rule 100050 uses 6 failures but the alert shows 5.

- Track per attacker: Make the rules count failures per source IP, not across the whole lab.